

CVEs más relevantes de la semana

Del 26/05/2026 al 02/06/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-44966

Descripción: Velocity.js is a JavaScript implementation of the Apache Velocity template engine. In 2.1.5 and earlier, a prototype pollution vulnerability was discovered in velocityjs. This issue occurs during the processing of #set directives in Velocity templates. If an application renders a template controlled by an attacker, it is possible to modify Object.prototype, potentially leading to Denial of Serv...

CVSS: 8.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:L

Tipo: CWE-1321

Tecnología: No especificado

Publicado el: 2026-05-26



CVE-2026-44985

Descripción: Dozzle is a realtime log viewer for docker containers. Prior to 10.5.2, the WebSocket upgrader for the /exec and /attach endpoints uses CheckOrigin: func(r *http.Request) bool { return true }, accepting upgrade requests from any origin. Combined with the JWT cookie using SameSite: Lax, this enables Cross-Site WebSocket Hijacking (CSWSH). An attacker hosting a page on a same-site origin (e.g., a ...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-346

Tecnología: No especificado

Publicado el: 2026-05-26



CVE-2026-8760

Descripción: The Login with OTP plugin for WordPress is vulnerable to authentication bypass in all versions up to, and including, 1.6. This is due to an incomplete fix for CVE-2024-11178: the rate-limit/lockout check added to `otpl_login_action()` was placed only inside the OTP-generation branch and is never evaluated on the OTP-validation branch, and the generated 6-digit OTP additionally has no expiration...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-307

Tecnología: No especificado

Publicado el: 2026-05-27



CVE-2026-7524

Descripción: IBM Langflow OSS 1.0.0 through 1.9.1 could allow remote code execution due to improper validation of symbolic links during archive extraction.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-05-27



CVE-2026-7876

Descripción: IBM Aspera HSTS for CP4I 1.5.1 through 1.5.19

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-05-27



CVE-2026-8175

Descripción: IBM Aspera High-Speed Transfer Endpoint 3.7.4 through 4.4.7 Fix Pack 1 and IBM Aspera High-Speed Transfer Server 3.7.4 through 4.4.7 Fix Pack 1 and IBM Aspera High-Speed Transfer Endpoint are affected by a buffer overflow in the asperahttpd component. This vulnerability could be exploited to cause a denial of service and potentially lead to authentication bypass or remote code execution.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-05-27



CVE-2026-48027

Descripción: Nx Console is the user interface for Nx & Lerna. On 19 May 2026, a malicious version of Nx Console, 18.95.0, was published at 12:30 PM UTC and removed soon after at 12:48 PM UTC, leaving it available for ~18 minutes in Visual Studio Marketplace. For OpenVSX, the problem was detected later, and the compromised version was available from 12:33 UTC to 13:09 UTC (~36 minutes).
Version 18.100.0 of N...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-506

Tecnología: No especificado

Publicado el: 2026-05-27



CVE-2026-24444

Descripción: SDMC NE6037 cable modem routers running firmware 7.1.6.0.25 and 7.1.6.1.9_B9 contain a hardcoded password vulnerability in the web management interface recovery endpoints (mgmt.php, npcmd.php) that allows unauthenticated attackers to gain root access by submitting the hardcoded credential to the recovery endpoint via HTTP. Attackers can leverage this hardcoded password to enable filtered SSH an...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-05-28



CVE-2026-34311

Descripción: Vulnerability in the Oracle Hospitality OPERA 5 Property Services product of Oracle Hospitality Applications (component: Opera). Supported versions that are affected are 5.6.19.24, 5.6.22, 5.6.25.19, 5.6.27.6 and 5.6.28. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Hospitality OPERA 5 Property Services. Successful attacks ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: NVD-CWE-noinfo

Tecnología: No especificado

Publicado el: 2026-05-28



CVE-2026-46833

Descripción: Vulnerability in the Net Service component of Oracle Database Server. Supported versions that are affected are 23.4.0-23.26.2. Difficult to exploit vulnerability allows unauthenticated attacker with network access via TLS to compromise Net Service. While the vulnerability is in Net Service, attacks may significantly impact additional products (scope change). Successful attacks of this vulner...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-05-28



CVE-2026-44881

Descripción: Portainer Community Edition is a lightweight service delivery platform for containerized applications that can be used to manage Docker, Swarm, Kubernetes and ACI environments. From 2.33.0 to before 2.33.8, 2.39.2, and 2.41.0, Portainer supports deploying stacks from Git repositories. When a Git-backed stack is created or updated, Portainer clones the repository using go-git v5, which translate...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-59

Tecnología: No especificado

Publicado el: 2026-05-28



CVE-2026-8809

Descripción: The Advanced Custom Fields: Extended plugin for WordPress is vulnerable to Privilege Escalation via Validation Bypass in all versions up to and including 0.9.2.5. The vulnerability exists due to the `after_validate_save_post()` function unconditionally trusting the attacker-controlled `_acf_post_id` POST parameter — with no authentication or integrity verification — to select a cleanup branch that ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-05-28



CVE-2026-9874

Descripción: Use after free in Dawn in Google Chrome prior to 148.0.7778.216 allowed a remote attacker to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Critical)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-05-28



CVE-2026-8732

Descripción: The WP Maps Pro plugin for WordPress is vulnerable to Privilege Escalation via Administrator Account Creation in all versions up to, and including, 6.1.0. This is due to the wpgmp_temp_access_ajax AJAX action being registered with wp_ajax_nopriv_ and protected only by a nonce check using the fc-call-nonce nonce, which is publicly embedded into every frontend page via wp_localize_script as the n...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2026-3655

Descripción: The OTP Login With Phone Number, OTP Verification plugin for WordPress is vulnerable to authentication bypass in versions 1.8.50 through 1.8.60. This is due to the Firebase verification flow in the ``lwp_ajax_register`` AJAX handler not binding the Firebase session to the phone number supplied in the request. The ``idehweb_lwp_activate_through_firebase()`` function validates that a Firebase OTP ses...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2025-41268

Descripción: Nozomi Networks Labs identified a CWE-23: Relative Path Traversal in the Administration WebUI in Waterfall WF-500 TX and RX Hosts in version 7.9.1.0 R2502171040 that allows remote unauthenticated attackers to delete arbitrary files on the Host machines.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-23

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2025-41269

Descripción: Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') in the Console WebUI in Waterfall WF-500 TX and RX Hosts in version 7.9.1.0 R2502171040 that allows remote unauthenticated attackers to execute arbitrary operating system commands on the device.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2025-41270

Descripción: Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') in the Console WebUI in Waterfall WF-500 TX and RX Hosts in version 7.9.1.0 R2502171040 that allows remote unauthenticated attackers to execute arbitrary operating system commands on the device.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2025-41272

Descripción: Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') in the Console WebUI in Waterfall WF-500 TX and RX Hosts in version 7.9.1.0 R2502171040 that allows remote unauthenticated attackers to execute arbitrary operating system commands on the device.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2025-41273

Descripción: Nozomi Networks Labs identified a CWE-288: Authentication Bypass Using an Alternate Path or Channel in the Console WebUI in Waterfall WF-500 TX and RX Hosts in version 7.9.1.0 R2502171040 that allows remote unauthenticated attackers to bypass authentication of the Console web application and perform actions as an authenticated user.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2025-41274

Descripción: Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') in the Console WebUI in Waterfall WF-500 TX and RX Hosts in version 7.9.1.0 R2502171040 that allows remote unauthenticated attackers to execute arbitrary operating system commands on the device.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2025-41275

Descripción: Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') in the Console WebUI in Waterfall WF-500 TX and RX Hosts in version 7.9.1.0 R2502171040 that allows remote unauthenticated attackers to execute arbitrary operating system commands on the device.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2025-41276

Descripción: Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') in the Console WebUI in Waterfall WF-500 TX and RX Hosts in version 7.9.1.0 R2502171040 that allows remote unauthenticated attackers to execute arbitrary operating system commands on the device.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2025-41277

Descripción: Nozomi Networks Labs identified a CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') in the Console WebUI in Waterfall WF-500 TX and RX Hosts in version 7.9.1.0 R2502171040 that allows remote unauthenticated attackers to execute arbitrary operating system commands on the device.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2026-10071

Descripción: DreamMaker developed by Interinfo has an Arbitrary File Upload vulnerability, allowing unauthenticated remote attackers to upload and execute web shell backdoors, thereby enabling arbitrary code execution on the server.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2026-46376

Descripción: FreePBX is an open source IP PBX. From 15.0.42 to before 16.0.45 and 17.0.7, unauthenticated users may be able to access the User Control Panel (UCP) using hard-coded initial template credentials if these were not immediately changed by the Administrator who enabled UCP. Authenticated access to ACP is required for the initial setup of UCP generic templates, but after that, without further steps...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2026-4290

Descripción: The WP Travel Pro plugin for WordPress is vulnerable to arbitrary user deletion via the `/wp-json/wp-travel/v1/travel-guide/{user_id}` REST API endpoint in all versions up to, and including, 10.6.0. This is due to the `check_permission()` callback unconditionally returning true and the `Database::delete()` method passing the user ID directly to `wp_delete_user()` without any role validation. This makes...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2026-45700

Descripción: FreeRDP is a free implementation of the Remote Desktop Protocol. Prior to 3.26.0, FreeRDP's planar bitmap decoder has an out-of-bounds heap write when decoding RLE planar data. In libfreerdp/codec/planar.c, freerdp_bitmap_decompress_planar() validates the X destination coordinate nXDst against the caller-provided destination stride (nDstStep) even when it is writing into the internal temp buffer...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-05-29



CVE-2018-25412

Descripción: Delta Sql 1.8.2 contains an arbitrary file upload vulnerability that allows unauthenticated attackers to upload malicious files by sending POST requests to docs_upload.php with crafted multipart form data. Attackers can upload PHP files with arbitrary content to the upload directory and execute them on the server for remote code execution.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-30



CVE-2026-10187

Descripción: A vulnerability was detected in Totolink N300RH 6.1c.1353_B20190305. Affected by this issue is the function setWiFiBasicConfig of the file wireless.so of the component Web Management Interface. Performing a manipulation of the argument KeyStr results in stack-based buffer overflow. The attack is possible to be carried out remotely. The exploit is now public and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-05-31



CVE-2026-44825

Descripción: Hardcoded credentials in the Basic Authentication setup tool (bin/solr auth enable) in Apache Solr versions 9.4.0 through 9.10.1 and 10.0.0 allows a remote attacker to gain full administrative access to the cluster via publicly known default credentials installed silently alongside the user-specified account.

As an immediate workaround without upgrading, delete the template users (superadmin,...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-06-01



CVE-2026-8644

Descripción: IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to identity spoofing.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-06-01



CVE-2026-9311

Descripción: IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to remote code execution caused by the bypass of security controls.

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-06-01



CVE-2026-9319

Descripción: IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to potential remote code execution due to deserialization of untrusted data via JAX-WS endpoints with WS-Security.

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-06-01



CVE-2018-25427

Descripción: Arm Whois 3.11 contains a stack-based buffer overflow vulnerability that allows remote attackers to execute arbitrary code by supplying oversized input to the IP address or domain field. Attackers can craft malicious input exceeding 658 bytes with shellcode to overwrite the structured exception handler and gain command execution when the application processes the input.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-06-01



CVE-2026-8206

Descripción: The Kirki – Freeform Page Builder, Website Builder & Customizer plugin for WordPress is vulnerable to privilege escalation via account takeover in all versions 6.0.0 to 6.0.6. This is due to the plugin accepting an arbitrary email address when a username is used in the password reset request. This makes it possible for unauthenticated attackers to send a password reset link for any user registe...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-06-02



CVE-2026-47117

Descripción: OpenMed before 1.5.2 contains a remote code execution vulnerability in the PII privacy-filter model loading path. The privacy-filter dispatcher used broad substring matching on the user-supplied model_name parameter, allowing a value such as attacker/foo-privacy-filter-bar to route through a path that loads Hugging Face models with trust_remote_code=True. An unauthenticated attacker can supply ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-06-02



CVE-2026-0611

Descripción: Spacelabs Healthcare Sentinel versions 10.5.x and higher and 11.x.x before 11.6.0 contain an unauthenticated remote code execution vulnerability through a deprecated .NET Remoting HTTP channel exposed on port 8989 that allows attackers to perform arbitrary file read and write operations by supplying valid .NET URI endpoints. Attackers can write ASPX webshells to the IIS wwwroot directory to ach...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-06-02



Resumen del Reporte

CVEs analizados: 38

Promedio CVSS: 9.57

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

